

LOGGING STANDARD

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Logging Standard
Document ID	STD-LOG-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Standard is authorized by the Information Security Policy (POL-ISP-001) and implements the Logging and Monitoring Policy (POL-LOG-001). It supports the SOC 2 Trust Services Criteria CC4.1, CC5.3, CC7.2 and CC7.3, HIPAA Security Rule 45 CFR §164.312(b), and GDPR Articles 5 and 32. It adopts published vendor logging guidance and states only the retention, alerting and review decisions that guidance leaves open.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 Overview and Purpose

This Standard sets what is logged, how long it is kept, what alerts on it, and what the review produces. PromptHalo Technologies (“the Company”) runs AWS, Google Workspace, GitHub and approved AI services, and every requirement here is met with a native platform feature.

The Company does not write its own configuration rules where a published benchmark already exists and is maintained by the platform vendor or by CIS. It adopts those benchmarks by name and version as its baseline, which means the Company inherits the maintenance effort rather than carrying it.

Vendor guidance decides which log types exist and how to enable them. It does not decide how long the Company keeps them, what it alerts on, or who reviews the result — and those are exactly what SOC 2 tests. This Standard is therefore short: adopt the guidance, then fix the four things it leaves open.

Which platform features emit the records, and how the accounts they run in are configured, belongs to the Cloud Platform Standard and is not restated here.

2 Scope

This Standard applies to records emitted by Company-controlled systems. It does not extend to personally owned devices; the Company operates no logging agent on them and collects nothing from them.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this Standard, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this Standard and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. This Standard implements the Logging and Monitoring Policy (POL-LOG-001). Where the two differ, the policy governs and this Standard is corrected at the next review. [SOC 2: CC5.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this Standard.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this Standard.
2. **Adopted baseline** — an externally published configuration benchmark the Company has adopted by name and version as its own requirement.
3. **Alert** — an automated notification raised when logged activity matches a detection rule.
4. **Audit log** — a system-generated record of an event, retained so that activity can be reconstructed afterwards.

5. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
6. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
7. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
8. **Disposition** — the recorded conclusion of triage, including the conclusion that an alert was not an incident.
9. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this Standard to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
10. **Log destination** — the storage location that receives and retains records from every log source.
11. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
12. **Population** — the complete set of instances of an event in a period, from which a sample can be drawn.
13. **Security Officer** — the individual accountable for day-to-day operation of the security program.
14. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
15. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 Adopted Guidance and Sources

The following are adopted as the Company's logging baseline. Between them they determine which log types are enabled and how.

1. AWS logging and monitoring guidance in the CIS AWS Foundations Benchmark and the Well-Architected Security Pillar, covering CloudTrail across accounts and regions and data events for storage holding client information. [SOC 2: CC7.2 · HIPAA §164.312(b)]
2. Google Workspace audit and investigation guidance, covering admin, login and OAuth grant logs. [SOC 2: CC7.2, CC6.1]
3. GitHub audit log and secret-scanning guidance for the organization and its repositories. [SOC 2: CC7.2, CC8.1]
4. For the Company's own application and agent records, no external guidance applies, so this Standard sets the requirement directly: enough context to reconstruct behavior, being the

triggering input, the tools invoked, the parameters used, the actions taken and the outcome.
[SOC 2: CC7.2, CC2.1]

5. Whatever the source, a record must establish what happened, when, from where, and the identity involved. A record that cannot answer those four questions is not sufficient, and that is the test rather than a prescribed field list. [SOC 2: CC7.2, CC2.1]

6 What the Guidance Leaves Open

Four decisions no vendor makes for the Company. These are the clauses SOC 2 samples.

1. Retention. All sources deliver to one destination — an S3 bucket in the dedicated logging account — with object lock or an equivalent write-once setting, retained for at least thirteen months and the most recent ninety days available for immediate query. Thirteen rather than twelve so a full observation period is covered with margin at both ends. [SOC 2: CC7.2, CC4.1]
2. Alerting. Five rules, chosen because each is high signal and low volume: root or organization-level account use, changes to logging configuration, new administrative grants, OAuth grants outside the allow-list, and secret-scanning findings. They deliver to security@prompthalo.com rather than a personal inbox, so the record survives a departure. [SOC 2: CC7.2, CC7.3]
3. Disposition. Every alert receives a recorded conclusion, including the conclusion that it was not an incident, and the complete population for a period is retained. A list of only the interesting ones is not a population. [SOC 2: CC7.3, CC2.1]
4. Review. Dispositions are reviewed monthly for production, recording the date, the reviewer, the period covered and the conclusion, with nil months recorded as such. Twelve reviews a year is what a Type II sample requires, and a missed month cannot be recreated; this is the requirement here most likely to fail on timing rather than design. [SOC 2: CC4.1, CC7.2]
5. Secrets, credentials, authentication tokens and client information are not written into records. Where they might appear, the field is redacted at source. [SOC 2: CC6.7 · C1.1]
6. Alerting coverage is reviewed annually against the five rules and adjusted where the estate has changed. A rule that fires constantly is a coverage problem to be tuned, not ignored. [SOC 2: CC7.2, CC4.1]

7 Records

1. The adopted guidance versions and the list of log sources with their delivery configuration. [SOC 2: CC2.1, CC5.3]
2. Retention and object-lock settings on the destination. [SOC 2: CC7.2]
3. The complete alert population for the period with each disposition. [SOC 2: CC7.3]
4. Twelve monthly review records a year, including nil months. [SOC 2: CC4.1]
5. The annual alerting coverage review. [SOC 2: CC7.2]

8 Exceptions

Where a source cannot deliver a required record, or a plan does not support the retention this Standard requires, the position is recorded by the Accountable Party with the compensating measure and a review date. Where no exceptions are in force, that is recorded affirmatively at the annual review.

9 Reference

- SOC 2 Trust Services Criteria, Security category [CC4.1, CC5.3, CC7.2, CC7.3]
- CIS Amazon Web Services Foundations Benchmark and AWS Well-Architected Security Pillar
- Google Workspace audit and investigation guidance
- GitHub audit log and secret-scanning guidance
- POL-LOG-001 Logging and Monitoring Policy [SOC 2: CC7.2]
- POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
- STD-CLD-001 Cloud Platform Standard [SOC 2: CC7.1]
- POL-IRP-001 Incident Response Policy [SOC 2: CC7.3]
- HIPAA Security Rule, 45 CFR §164.312(b)
- EU General Data Protection Regulation, Articles 5 and 32

1 DOCUMENT POLICY HISTORY

Version	Date	Description
1.0	August 18, 2026	Initial policy release